FR-03 – Step 1: Identify input & output variables

Spec used

Source: `eshop-sut/README.md` (FR-03, FR-01, SEC-07; FR-21 and FR-22 added after review) and `api_specification.md` (1.3, 1.4). Black-box: spec documents only, no source code.

> **FR-03: Forgot password & reset (2 steps)**
>
> **Step 1 – Get OTP:** User enters registered email. System generates a random 6-digit OTP and sends it by email (demo: shown on screen). UI shows a step indicator ("Bước 1 / 2"). Has a "Back to login" button.
>
> **Step 2 – Reset password:** User enters OTP, new password, confirm new password. New password must follow FR-01 rules. The two password fields must match. OTP is only valid for the email that requested it.
>
> **FR-01 (password rule):** min 8 characters, at least 1 uppercase, 1 lowercase, 1 digit, 1 special character from `@ $ ! % * ? &`.
>
> **SEC-07:** OTP must have enough entropy (min 6 digits), must expire, and must be invalidated after use.
>
> **FR-21 (general UI):** whole UI in Vietnamese; positive action buttons (Submit) are blue, destructive/cancel buttons red; exactly one `<h1>` per page; Tab focus order top-to-bottom, left-to-right.
>
> **FR-22 (forms):** every required field has a `*` next to its label; email fields use `type="email"`; password fields use `type="password"` (masked); error messages appear **above** the submit button; forms with 2+ steps have a clear step indicator.

Input variables

ID	Variable	Condition / constraint	Type	From spec or Assumption
FR-03_IN_01	Email (step 1)	Must be an email already registered in the system; format `user@domain.com`	Text	Spec (registered) + Assumption (format rule borrowed from FR-01)
FR-03_IN_02	"Back to login" button	Set: {clicked, not clicked}	Set	Spec
FR-03_IN_03	OTP (step 2)	Exactly 6 characters, digits 0–9 only; must equal the OTP issued for this email	Text (fixed length)	Spec
FR-03_IN_04	New password	Length ≥ 8; ≥1 uppercase, ≥1 lowercase, ≥1 digit, ≥1 special from {@ $! % * ? &}; max length not specified	Text / length	Spec (FR-01)
FR-03_IN_05	Confirm new password	Must be identical to FR-03_IN_04	Text	Spec

ID	Variable	Condition / constraint	Type	From spec or Assumption
FR-03_IN_06	OTP age (time from issue to use)	Must be less than the expiry time T; T not specified	Date/time	Spec (SEC-07: must expire) + Assumption (value of T)
FR-03_IN_07	OTP use count	Must be 0 when submitted (single use)	Number	Spec (SEC-07)
FR-03_IN_08	Email sent with the reset request (step 2, API field `email`)	Must equal the email that requested the OTP	Text	Assumption (field from API spec; rule from FR-03)
FR-03_IN_09	Number of OTP requests for the same email	Assumed only the most recent OTP is valid	Number	Assumption
FR-03_IN_10	Confirm-password field in reset API request	Set: {present & matching, present & not matching, absent}; API spec 1.4 has no such field	Set	Assumption
FR-03_IN_11	Step 1 completed before step 2	Set: {yes, no (step 2 reached directly)}	Set	Assumption

Output variables

ID	Variable	Condition / constraint	Type	From spec or Assumption
FR-03_OUT_01	Step indicator	Set: {"Bước 1 / 2", "Bước 2 / 2"} matching the current step	Set	Spec
FR-03_OUT_02	Generated OTP (displayed in demo)	6 random digits, shown on screen after a valid step 1	Text (fixed length)	Spec
FR-03_OUT_03	Error: email not registered	Shown when IN_01 is well-formed but unknown	Text	Assumption (wording)
FR-03_OUT_04	Error: invalid email format	Shown when IN_01 is not `user@domain.com`	Text	Assumption
FR-03_OUT_05	Error: required field empty	Shown when IN_01, IN_03, IN_04 or IN_05 is empty	Text	Assumption
FR-03_OUT_06	Error: incorrect OTP	Shown when IN_03 does not match the issued OTP	Text	Assumption (wording)
FR-03_OUT_07	Error: OTP expired	Shown when IN_06 ≥ T	Text	Spec (SEC-07) + Assumption (wording)
FR-03_OUT_08	Error: OTP already used	Shown when IN_07 ≥ 1	Text	Spec (SEC-07) + Assumption (wording)
FR-03_OUT_09	Error: OTP not valid for this email	Shown when IN_08 ≠ requesting email	Text	Spec (rule) + Assumption (wording)
FR-03_OUT_10	Error: password does not meet strength rules	Shown when IN_04 breaks any FR-01 rule	Text	Spec (FR-01) + Assumption (wording)
FR-03_OUT_11	Error: passwords do not match	Shown when IN_05 ≠ IN_04	Text	Spec + Assumption (wording)
FR-03_OUT_12	Success message: password reset	Shown when all step 2 inputs are valid	Text	Assumption

ID	Variable	Condition / constraint	Type	From spec or Assumption
FR-03_OUT_13	Redirect to login after successful reset	Set: {redirected, not redirected}	Set	Assumption (mirrors FR-01)
FR-03_OUT_14	Redirect to login via "Back to login"	Triggered by IN_02 = clicked	Set	Spec
FR-03_OUT_15	Account password after attempt	Set: {changed to new password (old rejected at login), unchanged}	Set	Assumption
FR-03_OUT_16	Required-field marker	A `*` next to the label of every required field (email; OTP, new password, confirm)	Set	Spec (FR-22)
FR-03_OUT_17	Email input type	`type="email"`	Set	Spec (FR-22)
FR-03_OUT_18	Password inputs type	New password and confirm use `type="password"` (masked)	Set	Spec (FR-22)
FR-03_OUT_19	Error message position	Shown above the submit button	Set	Spec (FR-22)
FR-03_OUT_20	Page heading	Exactly one `<h1>` on each step	Number	Spec (FR-21)
FR-03_OUT_21	Interface language	All labels, buttons and messages in Vietnamese	Set	Spec (FR-21)
FR-03_OUT_22	Submit button colour	Blue	Set	Spec (FR-21)
FR-03_OUT_23	Tab focus order	Top to bottom, left to right	Set	Spec (FR-21)

OUT_16–OUT_23 were **added after review**: FR-21 and FR-22 apply to every form but are not referenced from FR-03, so they were missed in the first version of this step (see the AI gap analysis). FR-22's step-indicator rule was already covered by OUT_01.

Ambiguities / questions about the spec

1. OTP expiry time T is not specified (SEC-07 only says "must expire").
2. Maximum password length is not specified.
3. Whether special characters outside `@$!%*?&` (e.g. `#`, `_`) count as "special". Strict reading: they do not.
4. Whether the email is trimmed and case-insensitive (`Test@eshop.com` vs `test@eshop.com`).
5. Whether requesting a new OTP invalidates the previous one.
6. The reset API has no confirm-password field, so the "must match" rule can only be enforced on the client.
7. Showing "email not registered" lets attackers enumerate accounts; FR-02 asks not to reveal failure details. The spec doesn't say which behaviour FR-03 should have.
8. No limit on wrong-OTP attempts is specified; a 6-digit OTP can be brute-forced without one.